

FinTrust Security Services Configuration

Summary

Executive Summary

FinTrust deployed a security-first architecture this week using **AWS Config, Secrets Manager, ACM, AWS WAF, Shield Standard, and SSM Session Manager**. The design emphasizes **continuous compliance monitoring, automatic credential rotation, secure TLS certificate management, application-layer threat protection, DDoS resilience, and auditable administrative access without bastion hosts**, supporting both regulatory compliance and operational security objectives.

Security Services Deployment Overview

Service	Configuration / Deployment	Why This Service Was Chosen
AWS Config	12 managed Config Rules monitoring encryption, public access controls, MFA requirements, logging, and compliance posture. Continuous configuration recording and compliance evaluation enabled.	Provides continuous compliance monitoring and detects configuration drift. Ensures POPIA and audit requirements are met by validating that AWS resources remain correctly configured over time. AWS Config answers <i>"Is the resource configured correctly?"</i> rather than <i>"Who changed it?"</i> .
AWS Secrets Manager	RDS credentials configured with automatic rotation every 60 days. Secrets stored using KMS encryption.	Chosen because automatic secret rotation is a native capability of Secrets Manager. This reduces the risk of credential compromise, supports security best practices, and removes

		manual password management overhead. Automatic rotation is the primary differentiator from Parameter Store.
AWS Certificate Manager (ACM)	Certificate deployed in us-east-1 (N. Virginia) for CloudFront integration.	CloudFront requires ACM certificates to exist in us-east-1, regardless of where the application or users are located. Using the correct region ensures successful HTTPS termination and automatic certificate renewal.
AWS WAF	Web ACL attached to the Application Load Balancer (ALB) with AWS Managed SQL Injection Rule Group and XSS Rule Group enabled.	Protects the application layer (Layer 7) from common web exploits. SQL injection and cross-site scripting attacks are particularly relevant to banking and financial applications handling customer data.
AWS Shield Standard	Automatically enabled on supported AWS services. Shield Advanced is currently under evaluation.	Provides baseline protection against common Layer 3 and Layer 4 DDoS attacks without additional configuration or cost.
AWS Systems Manager Session Manager	Replacing the traditional bastion host model. Session logging configured to CloudWatch Logs and/or S3 for auditing. Requires SSM Agent, IAM role, and outbound HTTPS connectivity.	Eliminates the need for open SSH/RDP ports, removes SSH key management requirements, reduces attack surface, provides centralized IAM-based access control, and delivers a complete audit trail for compliance requirements such as POPIA and SOC 2.

